AlphaDrafts Admin Panel

● STABLE & PRODUCTION READY

Executive & Technical Management Handover Report

DATE	VERSION / COMMIT	PREPARED FOR	STACK TARGET
October 10, 2026	v1.0.0 (efc4402)	Engineering & Product Leadership	Next.js 16 / Netlify OpenNext

1 Executive Summary

The AlphaDrafts Admin Panel (`alpha-drafts-admin-app`) serves as the primary internal operations back-office for managing users, academic drafting projects, subscription revenue, and system metrics. Over the recent development cycles, the application underwent an essential architectural migration and rigorous defect remediation to guarantee production stability.

> **Key Milestone Achieved:** The legacy Firebase Client & Admin SDK dependencies have been completely removed from client-side state. The application now runs on an enterprise-grade **cookie-based JWT authentication model** proxied to the Contabo backend, providing full double-submit CSRF protection and single-flight token rotation.

All core functional surfaces are verified operational. The application compiles cleanly with **0 TypeScript compiler errors**, **0 ESLint warnings**, and achieves instant page transitions via Next.js Pages Router and React 19.

2 Functional Surfaces Status Matrix

SURFACE	ROUTE	STATUS	BUSINESS CAPABILITIES & CAPABILITIES DELIVERED
Overview KPIs	`/admin/overview`	Production Ready	Executive KPI cards for total users, active subscriptions by tier (Starter, Student, Professional), revenue analytics, cumulative projects, and analyzer tool usage.
User Directory	`/admin/users`	Production Ready	50-record paginated table with sorting (`created_at`, `updated_at`), status tags, plan indicators, and direct `mailto:` outreach actions.
Project Tracking	`/admin/projects`	Production Ready	Project monitoring with status filtering (draft, in-progress, completed, archived) and null-safe rendering fallbacks.
Subscriptions	`/admin/subscriptions`	Production Ready	Multi-filtering billing ledger by tier and lifecycle state (active, inactive, failed). Price normalization converts backend units into USD currency strings.
Security Settings	`/admin/settings`	Operational	Admin profile viewer and password change form with client-side regex complexity validation (uppercase, lowercase, number, special char, length 6–20).
Auth & Recovery	`/`, `/auth/*`	Production Ready	Secure login, forgot-password modal dispatch, out-of-band password reset, and one-click email verification.
Admin Team Mgmt	`/admin/admins`	Safely Paused	Gated behind `ADMINS_ENABLED = false` until backend exposes dedicated admin membership endpoints.

3 Key Technical Defect Remediation Delivered

The following critical fixes and improvements were engineered and verified in the latest release (Commit `efc4402`):

Fixed **Table Link Navigation**

Replaced accidental Lucide `Link` SVG icon import with Next.js `next/link` in `Table.tsx`, restoring genuine client-side routing for table rows.

Fixed **Nested HTML Button Error**

Eliminated nested `<button>` violation in `MetricsCard.tsx` by converting outer card to `Link` and tooltip trigger to accessible focusable `span`.

Fixed **Super Admin Role Lockout**

Updated `AdminLayout.tsx` to accept both `["admin", "super_admin"]`, ensuring Super Admins are not erroneously redirected to unauthorized screens.

Fixed **Authorization Flashing**

Refactored `useAuthGuard.ts` to derive authorization state cleanly, preventing flashes of protected screens while permissions are resolving.

Fixed **Overview Loading UX**

Changed `isFetching` to `isLoading && !data` in `overview/index.tsx`, stopping intrusive full-screen blocking modals on background tab revalidation.

Fixed **React 19 Render Cascades**

Resolved 9 React 19 ESLint warnings across tables, modals, and tabs by converting synchronous `useEffect` copies into clean `useMemo` derivations.

4 Architecture & Security Highlights

The system enforces zero-trust boundaries between client UI and backend services:

- **Zero Host Hardcoding:** `API_BASE_URL = ""` throughout client components. Next.js server handles all routing via `next.config.ts` rewrites to .
- **HttpOnly Cookie Tokens:** `access_token` and `refresh_token` cannot be read by JavaScript, eliminating XSS token theft vectors.
- **Double-Submit CSRF Defense:** Non-httpOnly `csrf_token` cookie is mirrored into `X-CSRF-Token` header for all state-changing requests (POST, PUT, PATCH, DELETE).
- **Single-Flight Refresh Mutex:** `pendingRefreshPromise` de-duplicates concurrent 401s, preventing server refresh stampedes.

5 Deployment & Infrastructure Settings

CONFIGURATION	TARGET VALUE	OPERATIONAL NOTES
Hosting Platform	Netlify (OpenNext adapter)	Configured via root `netlify.toml` using `@netlify/plugin-nextjs`.
Build Command	`yarn build`	Runs `next build` with Turbopack optimization.
Publish Directory	`.next`	Managed automatically by the OpenNext Netlify plugin.
Node.js Version	`22`	Set in Netlify Site Settings as `NODE_VERSION=22`.
`BACKEND_URL`	Contabo Backend Origin URL	Server-only secret (no trailing slash, e.g. `https://api.alphadrafts.com`). *Never prefix with NEXT_PUBLIC_.*

6 Strategic Recommendations for Q4 2026

1. **Automated Regression Testing:** Install Vitest and React Testing Library to write unit tests for `useAuthGuard`, `apiClient` refresh loops, and currency formatting helpers.
2. **Edge Middleware (Defense-in-Depth):** Implement a root `middleware.ts` to inspect the `access_token` cookie at the Edge, redirecting unauthenticated requests before the HTML/JS bundle loads.
3. **Admin Management Endpoints:** Once the Contabo backend implements admin team membership CRUD endpoints, unpause the Admin Management UI by toggling `ADMINS_ENABLED = true` in `constants/admins.ts`.

Operational Sign-off & Verification

Engineering Lead / Technical Owner

Product Manager / Stakeholder